

PeerLink KACST Quarterly Vulnerability Assessment — 2026 Q3

Document control

Field	Value
Assessment ID	PeerLink - 2026 - Q3 - VA
Assessment date	11 August 2026
Application	PeerLink / P2P Manufacturing Knowledge Platform
Production endpoint	https://p2p.iiotsolutions.sa
Environment assessed	OCI production VM and control plane, public boundary, deployed services/images, source and dependencies
Assessment type	Internal, authorized, non-destructive quarterly vulnerability assessment
Prepared for	Internal IIoT Solutions review and Aadil's approval before any external submission
Production changes made	Application, dependency, image, Compose, OpenAPI, session and failed-login remediation deployed; host-package upgrades, credential rotation and SSH service changes were not performed

1. Executive summary

The 2026 Q3 assessment is complete for the defined scope. It combined a fresh OCI host/CIS/port scan, independent external network and TLS checks, public web configuration checks, dependency audits, static source and secret analysis, container image scanning, manual triage, local remediation, and regression/acceptance testing.

The assessment did **not** establish that production is vulnerability-free. It identified production actions and vendor-constrained residual risk that must remain visible:

- OCI VSS emitted 1,000 records at Critical/High/Medium severity, but 997 contain no vulnerable-package mapping. These are scanner records requiring validation, not 997 confirmed exploitable packages. Three mapped High records affect host `python3-pip / python3-wheel` and need an approved host-maintenance decision.
- OCI CIS passed 17 of 18 checks in its latest pre-release managed scan. Direct post-release verification confirmed a strong effective SSH MAC configuration; a fresh OCI-managed rescan remains required to reconcile the stale score.
- Production OpenAPI is now disabled (HTTP 404), and the complete browser defense-header set was verified after correcting an NGINX `add_header` inheritance issue in the deployed app shell.
- The deployed backend dependency tree reduced 34 advisory records to one High advisory in `cryptography` ; the available fixed version is incompatible with the current supported FastAPI-Mail constraint.
- The deployed backend image has four Critical and 20 High scanner records. Four Critical and 19 High OS records have no vendor fix in the active feed; one High dependency record is fixable only after resolving the mail compatibility constraint.

Material code/configuration risks were remediated and deployed: dependency updates, production OpenAPI suppression, mandatory untracked secrets, immutable copied application code, removal of reload mode and build tools, current base images, frontend security headers, and a compatible SuperTokens core update. Local regression/acceptance checks and production verification passed. Host-package remediation, credential rotation and a fresh OCI-managed rescan remain separate operational actions.

Assessment conclusion: the quarterly assessment, repository remediation, OCI deployment, and application-level production verification are complete. Credential rotation, host remediation, optional literal-duration captures, and reviewer sign-off remain pending. This distinction must be preserved in any KACST evidence package.

2. Scope

Included

1. OCI Vulnerability Scanning Service host findings.
2. OCI CIS benchmark result and effective SSH control follow-up.
3. OCI/internal port observations and independent external reachability.
4. Public DNS, HTTP-to-HTTPS redirect, TLS protocols/certificate and HTTP/2.
5. Public response headers, CORS behavior, unsafe methods and API schema exposure.
6. Frontend npm production/development dependency trees.
7. Backend Python dependency tree.
8. Backend static security analysis and tracked-source secret detection.
9. Backend and frontend production container images.
10. Production Compose, Dockerfiles, NGINX and runtime configuration.
11. Authentication/session regression, including Items 1 and 2 from the KACST follow-up.

Excluded or deferred

- Exploit attempts, credential attacks, denial-of-service/load testing and destructive testing.
- Authenticated production crawling or mutation of production data.
- Host package installation/upgrades, host restart, credential rotation or SSH service configuration change.
- WAF production DNS cutover and public SSH removal.
- Third-party SaaS/provider internals beyond externally visible behavior.
- A formal independent penetration test; this internal VA does not replace one if KACST requires an external assessor.

3. Method and safety controls

The assessment used a production-focused but non-destructive method:

1. Capture current OCI-managed scan results.
2. Verify public exposure independently rather than equating host-listening ports with internet reachability.
3. Perform low-rate public requests only: HEAD/GET, CORS preflight, rejected methods and TLS handshakes.
4. Audit dependencies and tracked source locally.
5. Build and scan candidate production images locally.
6. Triage every material finding for applicability, fix availability and confidence.
7. Implement safe repository remediation on a dedicated branch.
8. Retest locally, including prior KACST session and failed-login controls.
9. Deploy approved application remediation, verify the running OCI environment directly, and keep unresolved host, credential, and vendor actions explicitly open.

The repeatable runner is `scripts/run_quarterly_vulnerability_assessment.sh`. Production web checks require an explicit `--production-url`; the script never deploys, authenticates, restarts production or runs an active spider.

4. Results by assessment domain

4.1 OCI host vulnerability scan

The latest OCI host scan finished at `2026-08-11T01:13:39Z` and reported 1,000 records:

Scanner severity	Count
Critical	193
High	649
Medium	158
Total	1,000

Only three records contained vulnerable-package mappings, all High:

- `python3-wheel 0.42.0` with an ESM fix identified by OCI.
- `python3-pip 24.0+dfsg` with two ESM fixes identified by OCI.

The other 997 records did not identify an installed vulnerable package. Therefore, this report does not inflate the result into “193 confirmed Critical host packages.” They remain an urgent validation queue because the aggregate scan rating is Critical, but package presence, version, reachability and applicability must be established first.

4.2 OCI CIS benchmark

OCI evaluated 18 checks: 17 passed and one failed. The failed item is CIS 5.2.14, “Ensure only strong MAC algorithms are used.” This contradicts the intended July SSH hardening outcome and requires checking `sshd -T` and included configuration—not merely the text of one config file—during an approved window.

4.3 Network exposure

OCI observed host/internal services including duplicates across interfaces. Independent internet reachability established the actual public boundary:

- Reachable: TCP 22, 80 and 443.
- Filtered/unreachable: TCP 3567, 5173, 5432, 8000, 8520 and 27017.

Database, SuperTokens and application service ports were not directly internet-reachable. Public SSH remains an accepted, monitored exposure pending a tested Bastion cutover. HTTP and HTTPS are required application services.

4.4 TLS and public web baseline

Verified on the real production endpoint:

- HTTP redirects to HTTPS.
- HTTPS responds with HTTP/2 200.
- TLS 1.0 and 1.1 are rejected; TLS 1.2 and 1.3 are accepted.
- The Let's Encrypt certificate matches `p2p.iiofsolutions.sa` and was valid through 29 October 2026 at assessment time.
- HSTS and CSP are present.
- Untrusted-origin CORS preflight is rejected without `Access-Control-Allow-Origin`.
- TRACE, PUT and DELETE against `/` return 405.
- BrowserOps rendered the live application successfully under task `20260811-144834-peerlink-quarterly-vaproductio`.

The original baseline found public OpenAPI and missing defense-in-depth headers. Post-deployment retest on 12 August 2026 confirmed OpenAPI returns HTTP 404 and the public app shell now emits `X-Content-Type-Options`, `X-Frame-`

Options , Referrer-Policy , Permissions-Policy , HSTS and CSP. The final header correction was deployed in commit `bdb03b5` by successful workflow `31539611417` .

4.5 Dependency assessment

Tree	Baseline	Final verified result
Frontend npm	4 vulnerabilities	0
Backend Python	34 advisory records across 9 packages	1 advisory record

Backend remediation included current supported releases for FastAPI, Pydantic/settings, SuperTokens SDK, Motor/PyMongo, multipart/email validation, HTTPX, FastAPI-Mail and AWS libraries. Unused `python-jose` was removed, eliminating its unfixable ECDSA advisory path.

The remaining `cryptography 49.0.0` advisory is not hidden. Version 50.0.0 contains the fix, while FastAPI-Mail 1.6.5 currently constrains `<50` . Forcing an unsupported dependency graph was rejected. The accepted next action is an upstream-compatible mail release or a separately tested replacement of the mail abstraction.

4.6 Source and secret analysis

- Gitleaks 8.30.1: zero findings in tracked source (approximately 9.7 MB scanned, redacted mode).
- Bandit: zero High, one Medium/Low-confidence and ten Low findings.
- The Medium B608 item is a false positive: it matched an interpolated OCI Object Storage HTTPS URL in `s3_service.py` , not a SQL query.
- The ten Low B110/B112 findings are exception-swallowing/code-quality backlog items and should gain structured logging when touched.

A zero-result secret scan does not make previously tracked credentials safe. The production database/application values found in Compose were removed and must still be rotated because tracked values are considered exposed.

4.7 Container images and deployment configuration

Frontend image remediation produced a zero-finding Trivy result. Backend remediation reduced attack surface by:

- moving to a supported Debian 13/Python 3.11 base and applying available OS upgrades;
- removing curl/compiler packages from production;
- using Python's standard library for health checks;
- removing pip, setuptools and wheel after dependency installation;
- running as a non-root user;
- excluding nested virtual environments, documentation and local assets from build context;
- removing the source bind mount and `--reload` from production; and
- using four production workers.

Final backend image scan counts are 4 Critical, 20 High, 56 Medium, 66 Low and 33 Unknown. Of the Critical/High records, only the `cryptography` High has a fixed version in the scanner feed. These counts are reported rather than suppressed; vendor-unfixed OS records are subject to ongoing monitoring and future rebuild/retest.

4.8 SuperTokens compatibility regression and resolution

Updating the Python SDK exposed a real compatibility regression: core 11.0 supports CDI through 5.3, while SDK 0.31.3 requires 5.4. Core 12.0 supported the SDK but a direct local 11.0-to-12.0 database test produced a missing `time_joined` column during signup. The candidate was therefore not accepted.

Pinned core 11.3.7 supports CDI 5.4 and successfully upgraded an existing 11.0-created acceptance volume. Signup and the full failed-login acceptance suite passed afterward. A fresh-volume run also passed. Production was backed up and migrated to SuperTokens core 11.3.7. The deployed services and failed-login acceptance passed afterward.

5. Local remediation implemented

- Disabled Swagger, ReDoc and OpenAPI in production mode.
- Replaced tracked/default production database and app secrets with mandatory variables.
- Added `docker/.env.production.template` without secrets.
- Updated backend/frontend/SuperTokens dependencies and images.
- Hardened Docker build context and runtime images.
- Removed production source mount, reload process and root UID override.
- Added production worker process configuration.
- Added frontend container defense headers.
- Added a repeatable quarterly assessment runner.
- Preserved and updated isolated acceptance infrastructure.

6. Verification record

Check	Result
Backend unit/regression suite	32 passed, 0 failed
Existing security validation suite	126 passed, 0 failed
Failed-login acceptance	PASS, including existing-volume SuperTokens 11.0 – 11.3.7 path
Session-control acceptance	PASS (accelerated isolated timing)
Frontend full and production-only npm audit	0 vulnerabilities
Frontend production build	PASS
Frontend full lint	PASS — 0 errors and 0 warnings after pre-release baseline cleanup
Backend production image build/import	PASS
Frontend image build and NGINX syntax	PASS
Production/development/acceptance Compose parse	PASS
Tracked-source Gitleaks	0 findings
Final backend pip audit	1 known constrained advisory
Final frontend image Trivy	0 findings
Final backend image Trivy	4 Critical, 20 High; one fixable High

Accelerated local acceptance proves policy mechanics. The repository remediation and controls were subsequently deployed to OCI production. Workflow `31531595809` confirmed exact production settings, migration state, 32 tests inside the deployed image, and a live five-attempt lock transition. It is not represented as a literal eight-hour wall-clock browser capture or a real 15-minute recovery wait.

7. Production release update and remaining risk treatment

Application deployment run `31530596370` , verification run `31531595809` , operational-SSH run `31538887058` , and final browser-header correction run `31539611417` succeeded. Production currently runs commit `bdb03b512b56e6059ebd2c726b58bf8a64718006` . Validated application, SuperTokens, and MongoDB backups were created before each reconciliation. Backend, frontend, PostgreSQL, MongoDB, and SuperTokens were healthy after release. Full details are in `docs/Logs/2026-08-11-006-kacst-controls-oci-production-release.md` .

7.1 Direct post-production OCI VM verification — 12 August 2026 AST

After deployment, the OCI VM was accessed over SSH and the production environment was checked directly. The direct audit established:

- all five Compose services were running, with zero restarts/OOM kills; backend, PostgreSQL and MongoDB health checks passed;
- production migration `f4a9c2d78110`, 30-minute idle, eight-hour absolute, five-failure threshold and 15-minute lockout values were confirmed inside the running backend;
- 32 deployed-image tests passed and live failed-login behavior remained `401, 401, 401, 401, 429, 429` with cleanup;
- production OpenAPI returned 404, the full public browser-header set was present, TLS 1.0/1.1 was rejected, TLS 1.2/1.3 accepted, and the live UI rendered successfully;
- only TCP 22, 80 and 443 were reachable externally; database, SuperTokens, frontend/backend loopback ports and TCP 111 were blocked externally;
- a fresh Trivy scan of the **actual deployed images** reproduced the expected backend result (4 Critical, 20 High, 56 Medium, 66 Low and 33 Unknown; only the constrained `cryptography` High had a fix in the feed) and returned zero findings for the deployed frontend image;
- a fresh production-repository Trivy scan and tracked-source Gitleaks scan returned zero findings;
- OCI's latest managed scan remained the pre-release 11 August scan: 1,000 scanner records with only three package mappings, plus CIS 17/18. Direct package inspection confirmed `python3-pip` and `python3-wheel` remain installed, while effective `sshd -T` showed key-only authentication, no root login, MaxAuthTries 3 and only ETM SHA-2/UMAC-128 MACs. A fresh OCI CIS scan is still required to reconcile the stale failed score;
- 23 host package upgrades are currently available. Applying them may affect Docker/NGINX and remains an approved maintenance-window action; and
- GitHub shows 27 open Dependabot alerts against the repository's default-branch npm lockfile (1 Critical, 14 High, 11 Medium, 1 Low), while the assessed/deployed production branch returns zero from `npm audit` and the deployed frontend image returns zero from Trivy. The default branch must be synchronized/triaged rather than misreported as the production image result.

The findings register remains authoritative. Remaining operational actions are:

1. rotate production secrets outside source control in a coordinated window;
2. patch/remove mapped host packages and assess/apply the 23 pending host upgrades in an approved window;
3. rerun OCI VSS/CIS after host maintenance and reconcile CIS 5.2.14 against the verified effective SSH MAC list;
4. remove/disable unnecessary RPC port 111 host listeners as defense in depth, even though OCI blocks external reachability;
5. resolve the constrained `cryptography` advisory when a supported compatibility path exists;
6. synchronize and triage default-branch Dependabot alerts;
7. capture optional literal-duration role evidence if Aadil requests it; and
8. obtain Hamza technical-owner and Aadil reviewer sign-off.

8. Conclusion

PeerLink now has a fresh Q3 2026 assessment, triaged findings register, repeatable process, deployed repository remediation, OCI verification evidence, and a defined quarterly schedule. The package is suitable for Aadil's internal review. It must not be represented as KACST acceptance or as completion of the remaining host, credential-rotation, and reviewer actions.